CAPÍTULO IX

Discusión de resultados

Este capítulo interpreta los resultados del capítulo de Resultados frente a los criterios de aceptación de los tres objetivos específicos. No introduce mediciones nuevas.

IX.1. Pipeline de ingeniería de características

El extractor cumple el criterio del objetivo específico 1. El p95 mixto del ciclo de ida y vuelta a un `worker_threads` es de 0.0273 ms (Cuadro 7), frente al límite de 5 ms. La medición aísla la extracción y excluye la inferencia, el registro de eventos y la respuesta HTTP.

El incremento de latencia de extremo a extremo en Linux es de 12.08 ms en carga normal y de 12.85 ms en carga de ataque, más de 400 veces el costo del extractor (subsección VIII.3.2). La extracción no explica el sobrecosto del middleware. El middleware crea tres `worker_threads`, dos de Isolation Forest y uno de Random Forest (sección VIII.3.8), comunica los hilos por mensajes y persiste los eventos en SQLite. Este trabajo no midió el costo de cada componente por separado, y su atribución queda como trabajo futuro.

IX.2. Modelo híbrido

El Random Forest supera el F1 de 0.80 en las cuatro clases de ataque. El macro es de 0.9776, con un mínimo de 0.9239 en `cmdi` (Cuadro 9). El Isolation Forest alcanza un *recall* de 91.25 % con una tasa de falsos positivos de 5.46 %, frente a un mínimo de 50 % y un máximo de 10 % (Cuadro 10). Ambos criterios del objetivo específico 2 se cumplen con margen.

Estas cifras miden la separación entre clases dentro del corpus. Cuatro hechos acotan su lectura como estimación del desempeño en producción. El conjunto de prueba de `rf_v11` se leyó tres veces, el 24, el 25 y el 26 de septiembre de 2026 (cadena de locks en el anexo XIII.3), y se reporta la última lectura (0.9776), inferior a la de la primera (0.9843). El umbral de Isolation Forest también cambió entre esas lecturas, de 0.00807 a 0.00421; el historial de ese cambio se describe en la sección XIII.1.

El F1 se calcula por argmax y no incluye el umbral de decisión de 0.35, calibrado con `rf_v3` y sin recalibrar para `rf_v11` (sección VIII.5). Un barrido sobre validación confirma que el valor es estable entre 0.30 y 0.40, aunque no demuestra que sea óptimo (sección XIII.1). Además, 261 de las 1 468 filas de `cmdi` del conjunto de prueba (17.8 %) son sintéticas, y `cmdi` es la clase de menor

F1. Un cuarto hecho es que las particiones de validación y de prueba comparten la estructura de casi-duplicados del entrenamiento, mientras que la Ronda 5 es casi independiente de él (21 de 200 peticiones de `cmdi` tienen un vecino con $J \geq 0.8$; véase el anexo XIII.2).

El Isolation Forest no bloquea peticiones, porque el diseño reserva esa decisión al Random Forest. Su criterio se cumple como detector individual. Sobre el conjunto de validación, marca 19 de los 39 ataques que el Random Forest deja pasar, pero bloquear sus marcas agregaría 866 benignos bloqueados de más (sección XIII.1). Esas cifras son optimistas, porque el umbral de Isolation Forest se eligió sobre el mismo conjunto de validación.

IX.3. Falsos positivos y generalización

En la aplicación de referencia, ninguna petición benigna de Artillery recibió un 403. El escenario normal envió 6 300 solicitudes por repetición, incluido el calentamiento (subsección VIII.3.2). Con cadenas de User-Agent de navegadores reales se bloquearon 13 de 15 combinaciones (subsección VIII.3.2). Las cifras de Artillery (0 de 6 300, par B) y de navegadores (13 de 15, par A) corresponden a modelos distintos (sección VII.3.1).

En cuatro aplicaciones de terceros, el modelo bloqueó tráfico benigno con un User-Agent de navegador en las proporciones siguientes (subsección VIII.3.7). En dvws-node, el bloqueo fue de 92.5 % (37 de 40). En OWASP Juice Shop, el bloqueo fue de 97.1 % de peticiones benignas a las que el modelo asignó veredicto de bloqueo (312 peticiones, modo *monitor*). En DVNA, fue de 5 de 5 en una observación manual sin registro crudo.

En node-api-goat, fue de 50 de 50 en una ruta y de 4 de 5 en el chequeo de cinco peticiones (listado manual, sin registro crudo). Las muestras son pequeñas. Con `curl`, Juice Shop bajó a 39.4 %, y con el User-Agent por defecto de Node, dvws-node bajó a 75 %. En tres de las cuatro aplicaciones no consta el modelo exacto de cada medición (sección VII.3.1).

El User-Agent amplifica el bloqueo, pero no lo explica por completo: con `curl`, en Juice Shop, el veredicto de bloqueo se mantiene en el 39.4 %. El análisis SHAP (Cuadro 19) coincide: `ua_length` es la característica de mayor contribución en las clases `benign` y `sqli`. Solo el 0.4 % de las filas benignas del corpus tiene un User-Agent largo, frente a entre 33.3 % y 97.7 % en las clases de ataque (anexo XIII.4). El modelo aprendió esa diferencia del corpus.

Una explicación consistente con los datos es que el corpus benigno no representa el tráfico de aplicaciones reales. Este trabajo no la verificó con un corpus benigno alternativo. La recomendación de ampliar el corpus benigno y volver a medir estos falsos positivos se formula en el capítulo XI.

La exclusión por fuente, descrita en el anexo XIII.5, muestra un patrón parecido desde otro ángulo. Al excluir `modsec_learn`, `payloads_csv` o `xss_dataset`, la tasa de falsos positivos benignos sobre sus filas de validación sube de 0.1 %, 0.4 % y 0.2 % a 76.0 %, 27.0 % y 94.5 %. Al excluir `payload_full`, `seclists_cmdi` o `command_injection`, el bloqueo de ataques cae más de 25 puntos porcentuales, de 99.8 %, 100 % y 95.8 % a 73.7 %, 29.9 % y 56.3 %.

El control de mismo tamaño no reproduce estas caídas. El aumento de falsos positivos tiene el mismo sentido que el observado en las aplicaciones de terceros (sección VIII.3.7), sin establecer una relación causal. Estas cifras provienen de modelos de exclusión distintos del evaluado en este capítulo.

IX.4. Cobertura en la evaluación integrada

Con el corpus sin solapamiento (Cuadro 17; réplica de la query en el anexo XIII.6), la cobertura supera el 80 % en `sqli`, `path_traversal` y `cmdi` con ambos pares de modelos. Con el par A

(tarball e09120…; `rf_v10/if_v9`, métricas en el anexo XIII.7) es de 100 %, 85.0 % y 91.5 %, y con `rf_v11/if_v10` es de 99.5 %, 95.0 % y 96.0 %. El corpus es el mismo en ambas corridas, así que la diferencia de 10 puntos en `path_traversal` corresponde al cambio de tarball, que difiere también en versión del código (commits `c3d591a` y `22550ea`) y en número de características (67 frente a 69); no se aisló el efecto del modelo. Con el par A (tarball e09120…), el límite inferior del intervalo de Wilson (79.4 %) queda bajo el criterio, por lo que el cumplimiento con ese par es frágil (subsección VIII.3.6). La Ronda 5 no es una evaluación estrictamente ciega del modelo reconstruido: los resultados con el par A (tarball e09120…) se conocieron el 24 de septiembre y el modelo vigente se reconstruyó el 26, y el historial no vincula ambos hechos.

La Ronda 5 no incluye XSS. La cobertura de esa categoría proviene del corpus de 590 payloads de SecLists (Cuadro 15): 97.3 %, y 97.2 % al excluir las coincidencias con el entrenamiento. En ese corpus, los 200 payloads de `cmdi` coinciden con datos de entrenamiento, y su cobertura de 100 % no es evidencia de generalización. Con el criterio de igualdad normalizada, la cobertura de `sqli`, `xss` y `path_traversal` cambia como máximo 0.1 puntos al excluir las coincidencias; `sqli` y `path_traversal` no tienen coincidencias exactas (subsección VIII.3.5). Un caso hallado con OWASP ZAP se bloquea en las configuraciones 2, 3a y 3b (1 de 1); un solo caso no permite afirmar el cumplimiento del criterio para XSS (anexo XIII.8).

Sobre esos 590 payloads, ModSecurity (CRS, nivel de paranoia 1) bloqueó 93.2 %, logSguarDian 98.8 % y ambos en capas 99.5 %. De los 40 ataques que el WAF no bloqueó (11 de `sqli`, 3 de `xss` y 26 de `path_traversal`), logSguarDian bloqueó 37. Los tres restantes pasaron ambas capas, y ninguno de los 40 es de `cmdi`. El coautor ejecutó la comparación sobre el corpus de la Ronda 5 de forma provisional y sin que conste el paquete (cortafuegos solo, 532 de 600; en capas, 597 de 600; anexo XIII.8); esas cifras no se interpretan aquí.

IX.5. Latencia, memoria y CPU

El criterio del objetivo específico 3 (Δp95 $\leq$ 15 ms) se cumple en carga normal (12.08 ms) y de ataque (12.85 ms), con márgenes de 2.92 y 2.15 ms. No se cumple en volumen: el Δp95 es de 6 495.46 ms y el 7.00 % de las peticiones termina por tiempo de espera. Esas peticiones no entran en el p95, por lo que la cifra subestima la cola.

El protocolo fijaba un incremento de hasta 10 % de la latencia media sobre la línea base. Esta tesis reporta el incremento relativo del p95, que fue de +485.1 % y +278.1 % en carga normal y de ataque, y no reporta la media. El 10 % que se menciona aquí se calcula sobre la línea base de p95 (2.49 y 4.62 ms, que equivalen a 0.25 y 0.46 ms), no sobre la latencia media que fijaba el protocolo, que no se midió. El incremento relativo del p95 se presenta como indicador complementario y no como el criterio del protocolo. Los datos son de una sola corrida en un ejecutor de 2 vCPU, con cinco repeticiones por condición (subsección VIII.3.2).

La memoria aumenta 331.9, 332.0 y 375.9 MiB en ataque, normal y volumen, más del doble del límite de 150 MB (unos 143 MiB) (Cuadro 18). El incremento es casi igual en normal y ataque, lo que sugiere un costo fijo asociado a la carga de los modelos. Esa interpretación no se verificó. La CPU aumenta 85.1 y 88.9 puntos porcentuales (+529.6 % y +614.4 %) en ataque y normal, frente a un límite de 15 %. El contenedor completo usa entre 394.8 y 459.1 MiB y no se probó en una instancia de 1 GB, para la que se fijó el límite (sección VIII.3.8).

IX.6. Comparación con trabajos previos

IntelliWAF [1] combina un Random Forest y un Isolation Forest con reglas y limitación de tasa, y opera como proxy inverso externo a la aplicación. Reporta una exactitud de 91.5 % del Random Forest sobre CSIC 2010 (61 065 muestras) y no reporta latencia de detección. Este trabajo difiere en la arquitectura, embebida en el proceso de la aplicación, y en el papel del Isolation Forest, que no participa en el bloqueo. Las diferencias de conjunto de datos y de métrica impiden comparar cifras de detección.

IX.7. Cumplimiento de los objetivos

El Cuadro 21 resume el cumplimiento de los criterios de aceptación de cada objetivo específico y de los criterios del protocolo.

Objetivo	**Criterio**	**Resultado**	**Estado**
Objetivo general	Detección de amenazas conocidas y de variantes desconocidas, sin comprometer el rendimiento del servidor	Variantes desconocidas: solo evidencia indirecta (Isolation Forest marca 19 de 39 ataques que Random Forest deja pasar, en validación); memoria (+332 MiB) y CPU (+530 % a +614 %) incumplidas	Parcial
OE1	Extractor $\leq$ 5 ms por petición	0.0273 ms (ida y vuelta al *worker*; extractor en aislamiento, el sobrecosto del middleware completo es de 12 ms)	Cumple
OE2	F1 $\geq$ 0.80 en al menos 3 de 4 clases	4 de 4 (mínimo 0.9239)	Cumple
OE2	*Isolation Forest*: *recall* $\geq$ 50 %, falsos positivos $\leq$ 10 %	91.25 % y 5.46 %	Cumple
OE3	Cobertura $\geq$ 80 % por categoría	99.5, 95.0 y 96.0 % en `sqli`, `path_traversal` y `cmdi`; XSS: 97.3 % sobre el corpus de 590	Cumple; XSS sin corpus limpio
OE3	Δp95 $\leq$ 15 ms	12.08 ms (normal) y 12.85 ms (ataque)	Cumple; volumen no cumple
Falsos positivos en aplicaciones de terceros	Sin criterio formal	92.5 % de bloqueo en dvws-node y 97.1 % de veredictos de bloqueo en Juice Shop (modo *monitor*) de tráfico benigno con User-Agent de navegador	Limitación
Protocolo	Memoria adicional $\leq$ 150 MB	+332 MiB	No cumple
Protocolo	ΔCPU $\leq$ 15 %	+530 % a +614 %	No cumple

Cuadro 21: Cumplimiento de los criterios de aceptación por objetivo específico y criterio del protocolo.

Fuente: capítulo de Resultados (Cuadros 7, 9, 10, 17, 15 y 18, y subsección VIII.3.2). Elaboración propia. OE: objetivo específico.

Vo.Bo.: (f) _____

Ing. Erick Francisco Marroquín Rodríguez

Fecha de aprobación: Guatemala, _____ de _____ de 2026.

Versión del 13 de octubre de 2026